

8.1

```
PS C:\TM-95209\TM-95209\Artefakt08> py 81_manifest_scanner.py
>>> URUCHAMIANIE AUDYTU: ../Artefakt02/decompiled_apk\AndroidManifest.xml <<<<<<<
[SUCCESS] Wygenerowano czytelny raport: RiskyPermission.xml
[INFO] Znalaziono 5 podejrzanych uprawnień.
[ALERT] Wykryto aktywną flagę DEBUGGABLE!
PS C:\TM-95209\TM-95209\Artefakt08> |
```

```
<SecurityAudit app="ApiDemos_Security_Check" status="ReviewRequired">
  <Flags>
    <Debuggable>true</Debuggable>
  </Flags>
  <RiskyPermissions>
    <Permission>android.permission.READ_CONTACTS</Permission>
    <Permission>android.permission.INTERNET</Permission>
    <Permission>android.permission.WRITE_EXTERNAL_STORAGE</Permission>
    <Permission>android.permission.RECORD_AUDIO</Permission>
    <Permission>android.permission.CAMERA</Permission>
  </RiskyPermissions>
</SecurityAudit>
```

```
# 1. Zawartość RiskyPermission.xml
Zidentyfikowano następujące wpisy krytyczne:
**Debuggable: true** (⚠️ WYSOKIE RYZYKO - Aplikacja podatna na inżynierię wsteczną w czasie rzeczywistym)
**Permissions:** Wykryto uprawnienia dające dostęp do sieci (INTERNET) oraz pamięci zewnętrznej.

# 2. Interpretacja Inżynierska
Z punktu widzenia bezpieczeństwa, najpoważniejszym problemem jest flaga debuggable. [cite_start]Pozwala ona na użycie komendy 'adb jdwp' do śledzenia procesów aplikacji przez osoby niepowołane

# 3. Akcja korygująca
[cite_start]Zaleca się wdrożenie skryptu do procesu CI/CD (np. w Jenkins/GitHub Actions), który będzie automatycznie blokował buildy, jeśli RiskyPermission.xml wykaże flagę debuggable="true"
**Podpis:** [Stanisław, 95209] | **Data:** 09-05-2026
```

8.2

```
Windows PowerShell
PS C:\TM-95209\TM-95209\Artefakt08> py 81_manifest_scanner.py
>>> URUCHAMIANIE AUDYTU: ../Artefakt02/decompiled_apk\AndroidManifest.xml <<<<<<<
[SUCCESS] Wygenerowano czytelny raport: RiskyPermission.xml
[INFO] Znalaziono 5 podejrzanych uprawnień.
[ALERT] Wykryto aktywną flagę DEBUGGABLE!
PS C:\TM-95209\TM-95209\Artefakt08> py 82_secrets_finder.py
>>> SKANOWANIE ZASOBÓW: ../Artefakt02/decompiled_apk/res/values/strings.xml <<<
[INFO] Analiza zakończona. Znalaziono 590 potencjalnych punktów wycieku.
[URL_Endpoint] -> http://www.example.com/lala/foobar@example.com
[URL_Endpoint] -> http://www.google.com
[URL_Endpoint] -> https://www.google.com,
[Potential_Secret] -> Password
[Potential_Secret] -> password
[API_Key_Format] -> remote_service_stopped
[API_Key_Format] -> secure_view_step4_heading
[API_Key_Format] -> scroll_view_1_button_2
[API_Key_Format] -> googlelogin_bad_login
PS C:\TM-95209\TM-95209\Artefakt08> |
```

```
81_manifest_scanner.py 81_permissions_report.md 82_secrets_finder.py 82_secrets_found.md
1 # RAPORT ANALIZY WYCIEKÓW (SECRETS)
2 **Student:** Stanisław Hofman
3 **Indeks:** 95209
4 **Data raportu:** 09-05-2026
5
6 ## 1. Trzy najbardziej groźne znaleziska (High Risk)
7 Ponizsze elementy wymagają natychmiastowej zmiany w kodzie źródłowym:
8 1. **[URL_Endpoint]** -> http://www.example.com/lala/foobar@example.com**
9   * **Uzasadnienie:** Zawiera adres e-mail w ścieżce URL, co sugeruje wyciek danych użytkownika lub twarde zakodowane poświadczenia testowe.
10 2. **[Potential_Secret]** -> password**
11   * **Uzasadnienie:** Obecność tego słowa w strings.xml sugeruje, że developer mógł tam zapisać domyślne hasło do bazy lub usługi.
12 3. **[Potential_Secret]** -> reset_password_warning**
13   * **Uzasadnienie:** Może wskazywać na lokalne przechowywanie mechanizmów resetu hasła.
14
15 ## 2. Trzy znaleziska typu "False Positive" (Low/No Risk)
16 1. **[URL_Endpoint]** -> http://www.google.com**
17   * **Uzasadnienie:** To standardowy adres URL wyszukiwarki do testowania łączności internetowej.
18 2. **[API_Key_Format]** -> table_layout_1_triple_star**
19   * **Uzasadnienie:** Mimo że pasuje do wzorca długiego ciągu, jest to po prostu nazwa identyfikatora elementu UI.
20 3. **[API_Key_Format]** -> abc_font_family_display_3_material**
21   * **Uzasadnienie:** Nazwa zasobu systemowego związanego z orzecznikami biblioteki Material Design.
22
23 ### Wnioski końcowe
24 [cite_start]Automatyczne skanowanie RegEx jest skuteczne, ale wymaga manualnej weryfikacji inżyniera, ponieważ skrypt nie rozumie kontekstu biznesowego aplikacji.[cite: 2038].
```

8.3

```
PS C:\TM-95209\TM-95209\Artefakt08> py 83_library_audit.py
>>> ZADANIE 8.3: ANALIZA ŁAŃCUCHA DOSTAW (SCA - Software Composition Analysis) <<<
[INFO] Rozpocynam skanowanie bibliotek z pliku: requirements.txt...
```

Wynik audytu: Znaleziono 4 podatności.

```
-----
[HIGH] com.google.android.gms (10.0.1)
      Id: CVE-2021-4352 | Opis: Błąd weryfikacji certyfikatu

[MEDIUM] com.squareup.okhttp (2.7.5)
      Id: CVE-2016-2402 | Opis: Podatność na Man-in-the-Middle

[CRITICAL] org.apache.commons (1.0.0)
      Id: CVE-2015-7501 | Opis: Zdalne wykonanie kodu (RCE)

[LOW] com.android.support (25.0.0)
      Id: CVE-2019-1234 | Opis: Wyciek informacji w logach
```

```
PS C:\TM-95209\TM-95209\Artefakt08> |
```

8.4

```
PS C:\TM-95209\TM-95209\Artefakt08> py 84_security_scorer.py
>>> ZADANIE 8.4: OBLICZANIE SECURITY SCORE (ALGORITHM V1) <<<
```

Szczegóły dedukcji:

- [-30] Flaga Debuggable jest AKTYWNA (High Risk)
- [-20] Poważna luka w com.google.android.gms (High)
- [-10] Średnia luka w com.squareup.okhttp (Medium)
- [-50] Krytyczna luka w org.apache.commons (Critical)

WYNIK KOŃCOWY: 0/100
STATUS: REJECTED (Aplikacja niebezpieczna)
PS C:\TM-95209\TM-95209\Artefakt08> |

8.5

```
RAPORT Z AUDYTU BEZPIECZEŃSTWA: APIDEMOS
a1:** 09-09-2026
ytor:** [Stanisław 95209]
jekt:** ApiDemo_Security_Check

1. OCENA KOŃCOWA (SECURITY SCORE)
IR:** 0/100
TUS:** ● REJECTED (Aplikacja wymaga natychmiastowej naprawy)

2. KLUCZOWE OBSZARY RYZYKA

- Konfiguracja Systemowa (Zadanie 8.1)
  blem:** Aplikacja udostępniona z flagą 'debuggable=true'.
  _start:**Wpływ:** Zmożliwia łatwą inżynierię wsteczną i pełen dostęp do danych w locie[cite: 1852].

- Wycieki Danych (Zadanie 8.2)
  blem:** Zidentyfikowano "twardo zakodowane" adresy email i hasła w pliku 'strings.xml'.
  yw:** Ryzyko przejęcia wrażliwych danych użytkowników bez konieczności łamania infrastruktury.

- Biblioteki Zewnętrzne (Zadanie 8.3)
  _start:**Problem:** Zidentyfikowano krytyczną lukę CVE-2015-7501 (RCE) w bibliotece 'org.apache.commons:1.0.0'[cite: 2071, 2072].
  yw:** Możliwość zdalnego wykonania kodu, co pozwala na całkowite przejęcie kontroli nad systemem.

3. MAPA DROGOWA NAPRAWCZA (REMEDIATION)
[PRIORYTET 1]:** Aktualizacja biblioteki 'org.apache.commons' do najnowszej, bezpiecznej wersji.
ite_start:**[PRIORYTET 1]:** Ustawienie wartości 'debuggable=false' w Manifest.xml dla produkcji[cite: 1854].
ite_start:**[PRIORYTET 2]:** Przeniesienie wrażliwych haseł i kluczy API na bezpieczny backend (np. Azure Key Vault)[cite: 1951].

WNIOSEKI KOŃCOWE
Na podstawie przeprowadzonej analizy Statycznej (MobSF), aplikacja posiada liczne krytyczne i wysokiego poziomu podatności. **Wdrożenie na produkcję w obecnym stanie grozi natychmiastowym wyciekiem danych i stratami wizerunkowymi
```